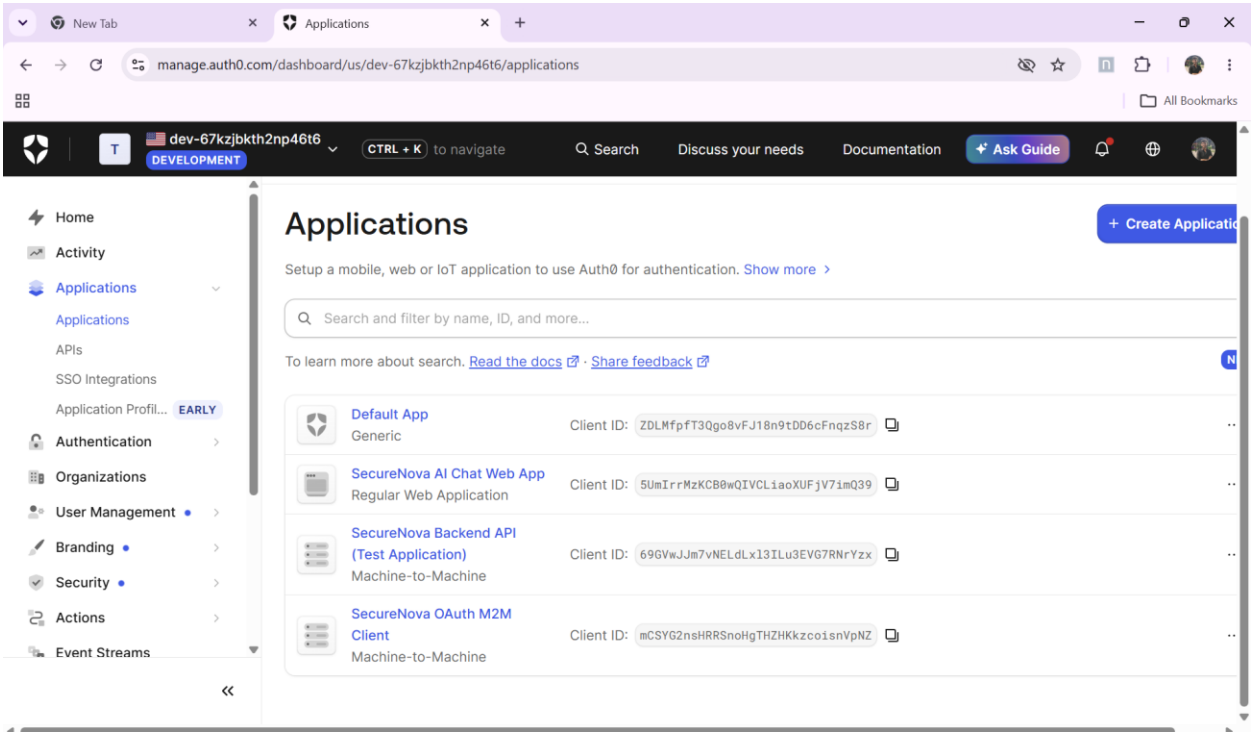
Project 2 — Build and Secure the Auth0-Backed AI Application

Summary

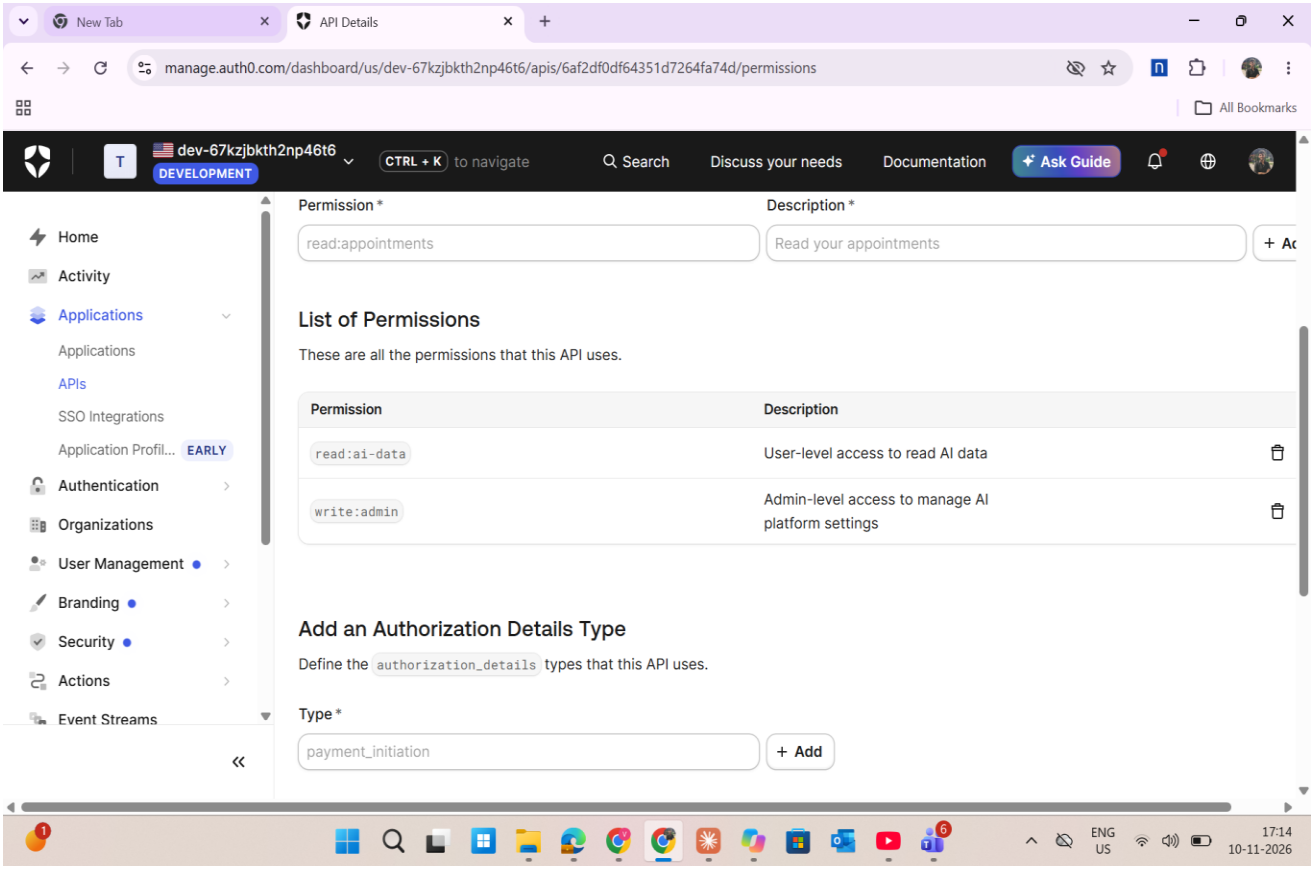
This document provides screenshot evidence for Project 2. An Auth0 developer tenant was configured with a Regular Web Application for the AI chat service and a Machine-to-Machine application for the AI agent. A protected API exposes two custom scopes, read:ai-data and write:admin, and a local Flask application enforces them, returning 403 when a user-level token calls the admin endpoint. Tokens are RS256-signed and carry a custom agent_id claim added by a post-login Action. TOTP MFA, Universal Login branding, Brute-force Protection and Suspicious IP Throttling are enabled. A Python script proves that a 60-second M2M token is rejected with 401 after expiry.

1 — Auth0 Applications page — Regular Web App and M2M app registered:



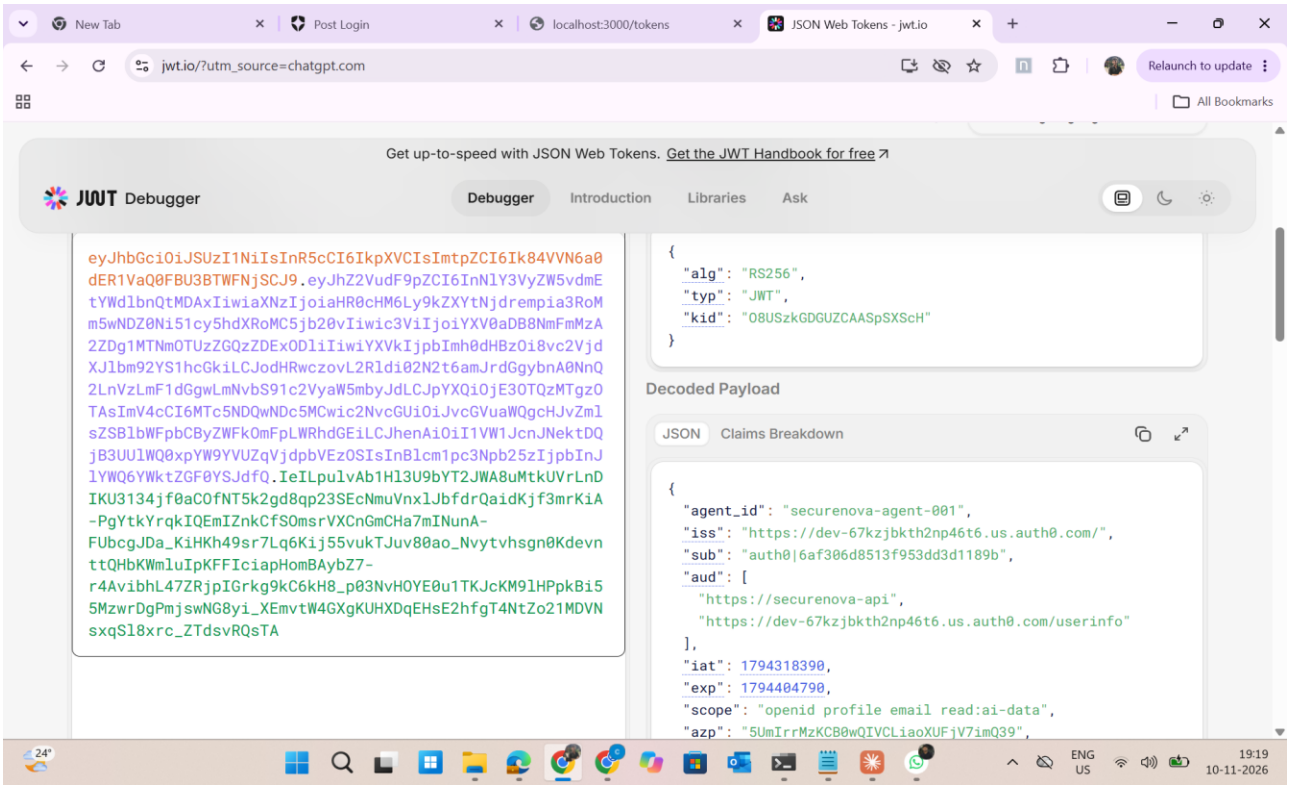
Description: The Auth0 dashboard Applications page for tenant dev-67kzjbkth2np46t6 shows both required applications: "SecureNova AI Chat Web App" (Regular Web Application) for the user-facing chat service, and "SecureNova OAuth M2M Client" (Machine-to-Machine) for the AI agent. Callback URLs, grant types and CORS origins were configured for each.

2 — Auth0 APIs page — custom scopes read:ai-data and write:admin



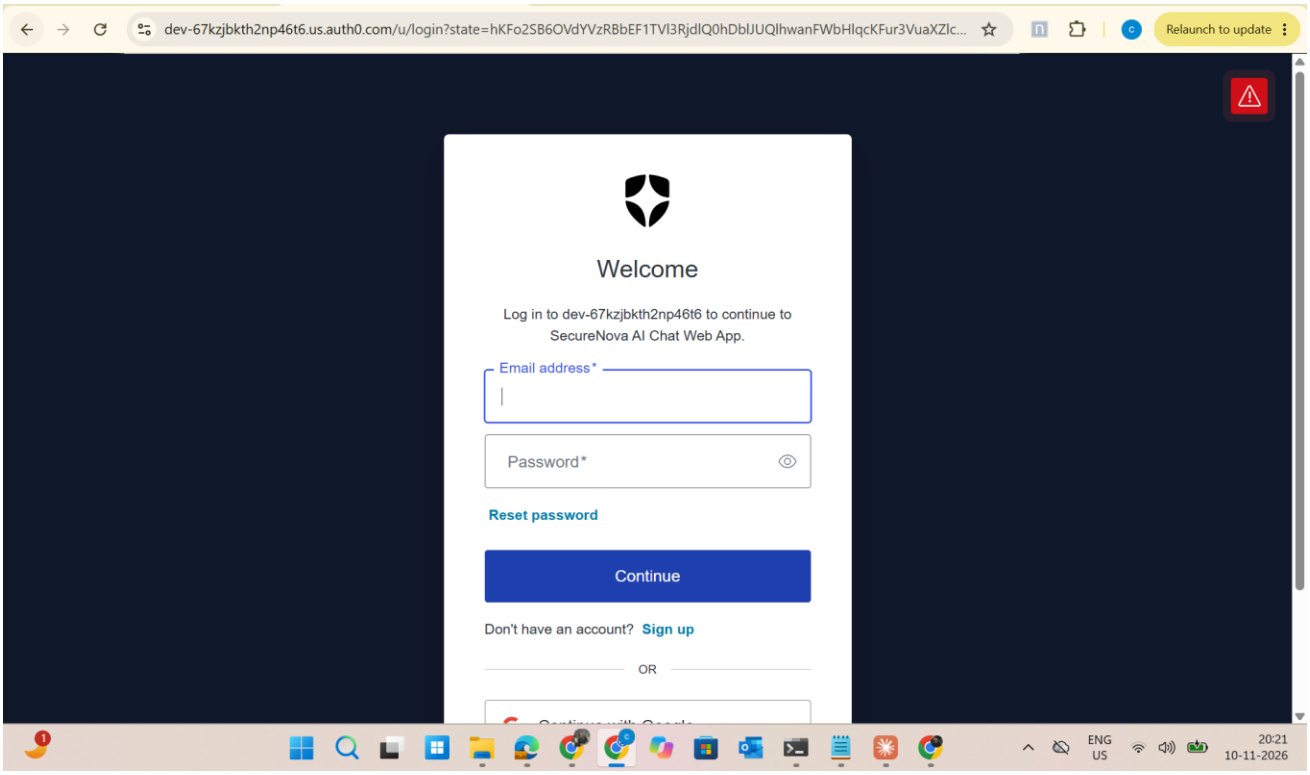
Description: The SecureNova Backend API (audience https://securenova-api) defines exactly two custom permissions: read:ai-data (user-level access to read AI data) and write:admin (admin-level access to manage AI platform settings).

3 — jwt.io — decoded access token (RS256, aud, iss, exp, scope, agent_id):



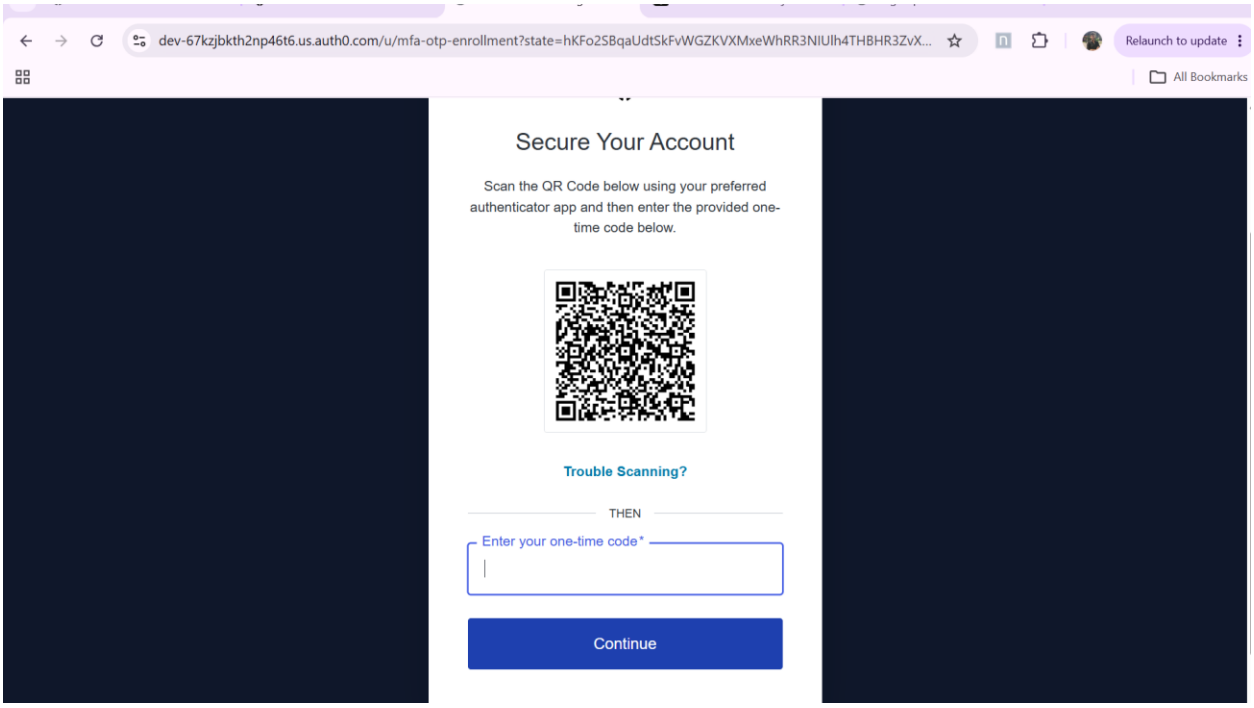
Description: The access token issued to the normal user was decoded at jwt.io. Header: alg = RS256. Payload: iss = https://dev-67kzjbkth2np46t6.us.auth0.com/, aud = https://securenova-api, exp present, scope = "openid profile email read:ai-data" (no admin scope), and the custom claim agent_id = "securenova-agent-001" added by the post-login Action.

4 — Auth0 Universal Login page with custom branding applied



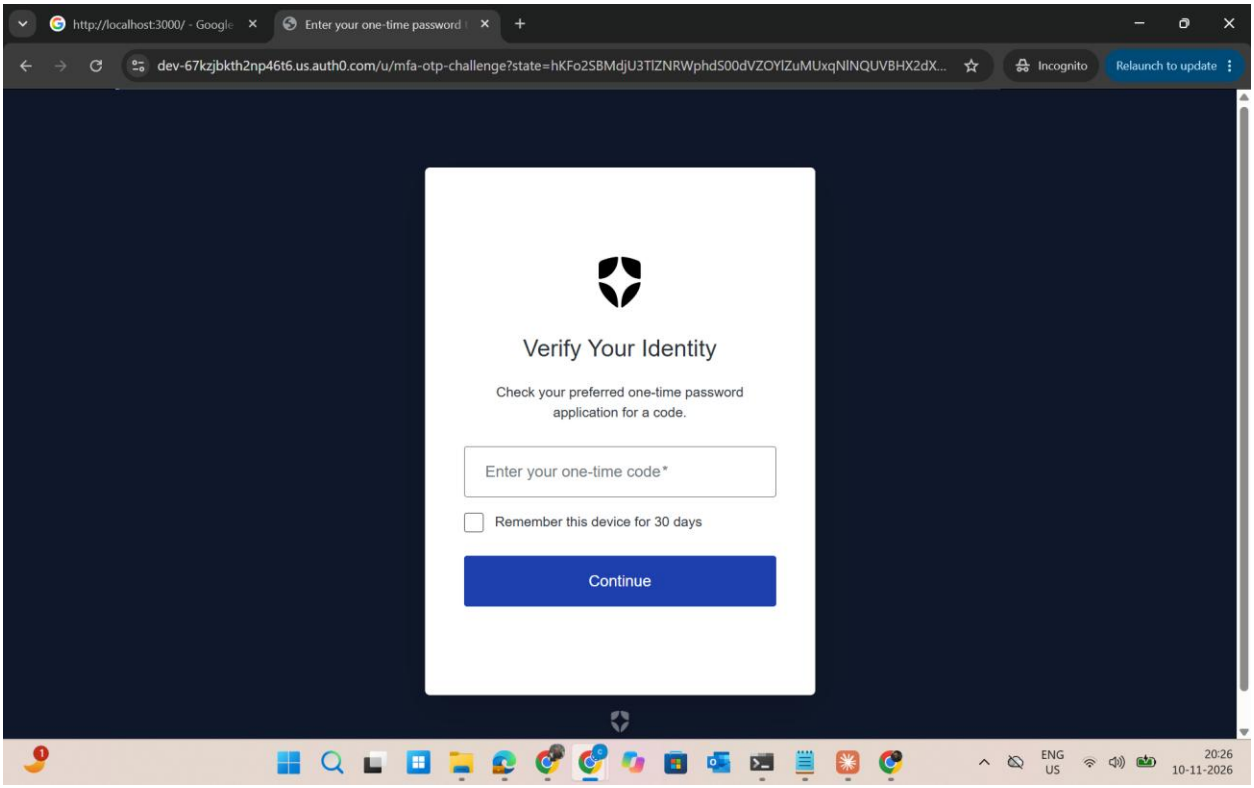
Description: The Universal Login page served from dev-67kzjbkth2np46t6.us.auth0.com/u/login shows the custom SecureNova branding theme: navy page background (#0F172A) and dark blue primary button (#1E40AF), applied via Branding > Universal Login.

5a — Auth0 MFA enrolment — TOTP QR code



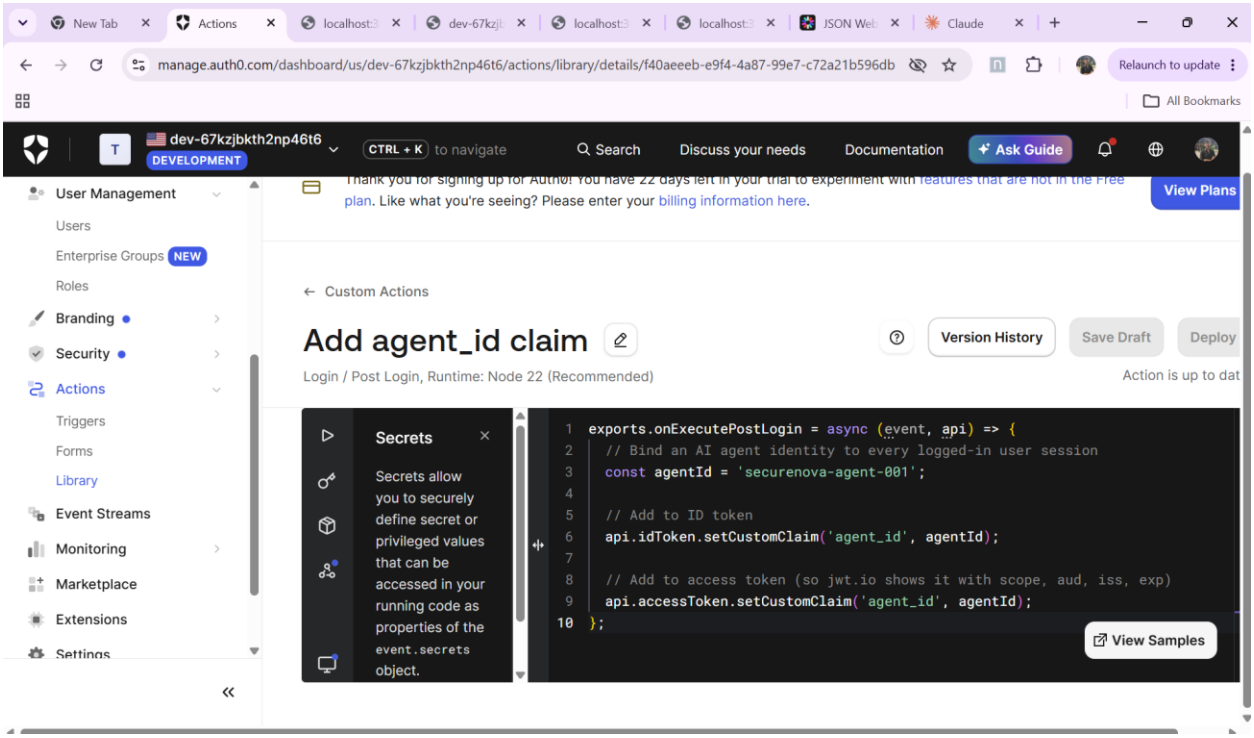
Description: With One-time Password (TOTP) enabled and MFA policy set to Always, a first login is redirected to /u/mfa-otp-enrollment, where the user scans the QR code with an authenticator app (Google/Microsoft Authenticator) and confirms a 6-digit code.

5b — Auth0 MFA challenge — TOTP code required at login



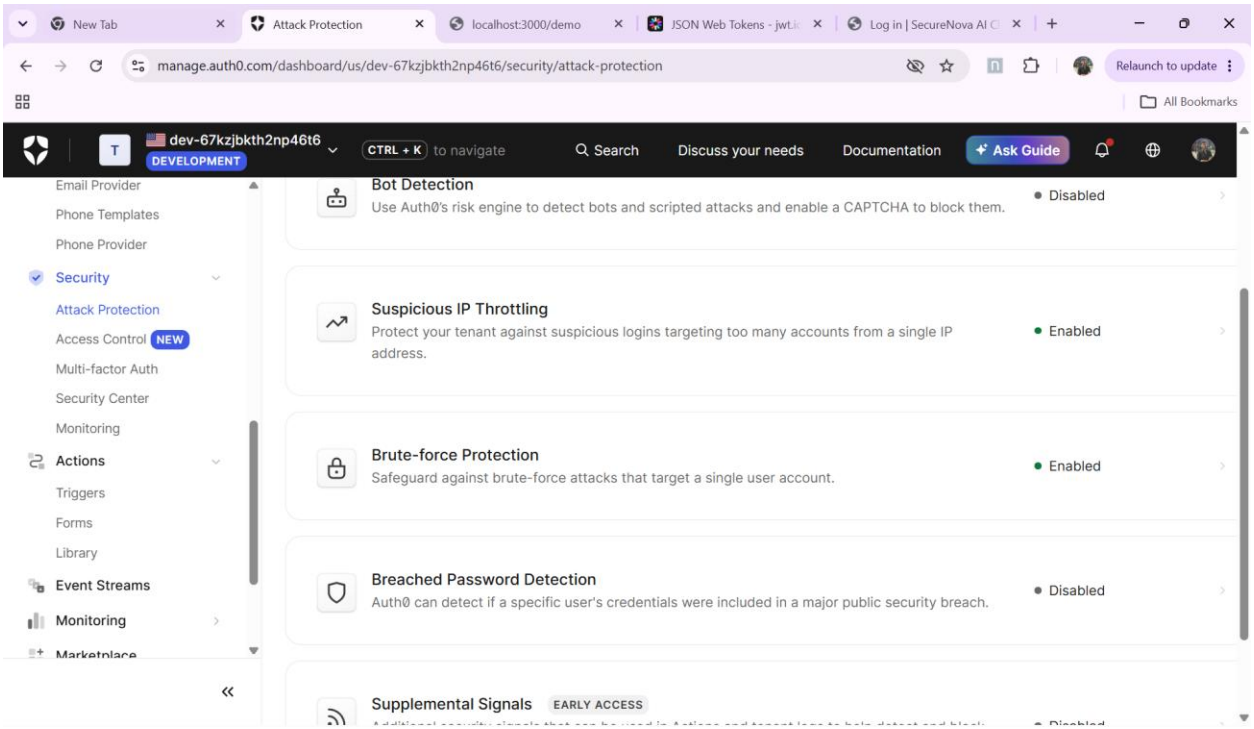
Description: On a subsequent login in a fresh incognito session, Auth0 presents the /u/mfa-otp-challenge page ("Verify Your Identity"), requiring the time-based one-time code before access is granted. This confirms the full enrolment and challenge flow.

6 — Auth0 Actions editor — post-login Action adding agent_id claim



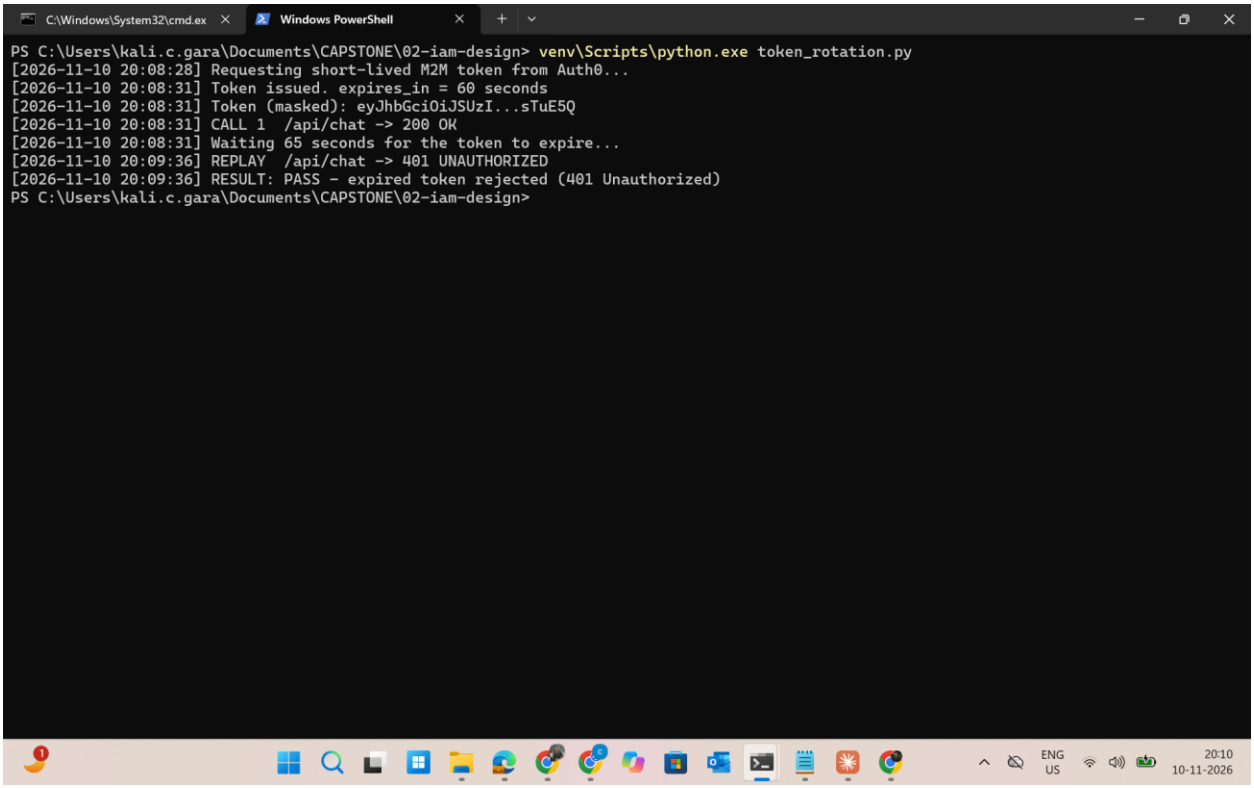
Description: The custom post-login Action "Add agent_id claim" (Node 22) sets agent_id = "securenova-agent-001" on both the ID token and the access token via api.idToken.setCustomClaim and api.accessToken.setCustomClaim. The Action is deployed and bound to the Login / Post Login trigger.

7 — Auth0 Attack Protection — Brute-force Protection and Suspicious IP Throttling enabled



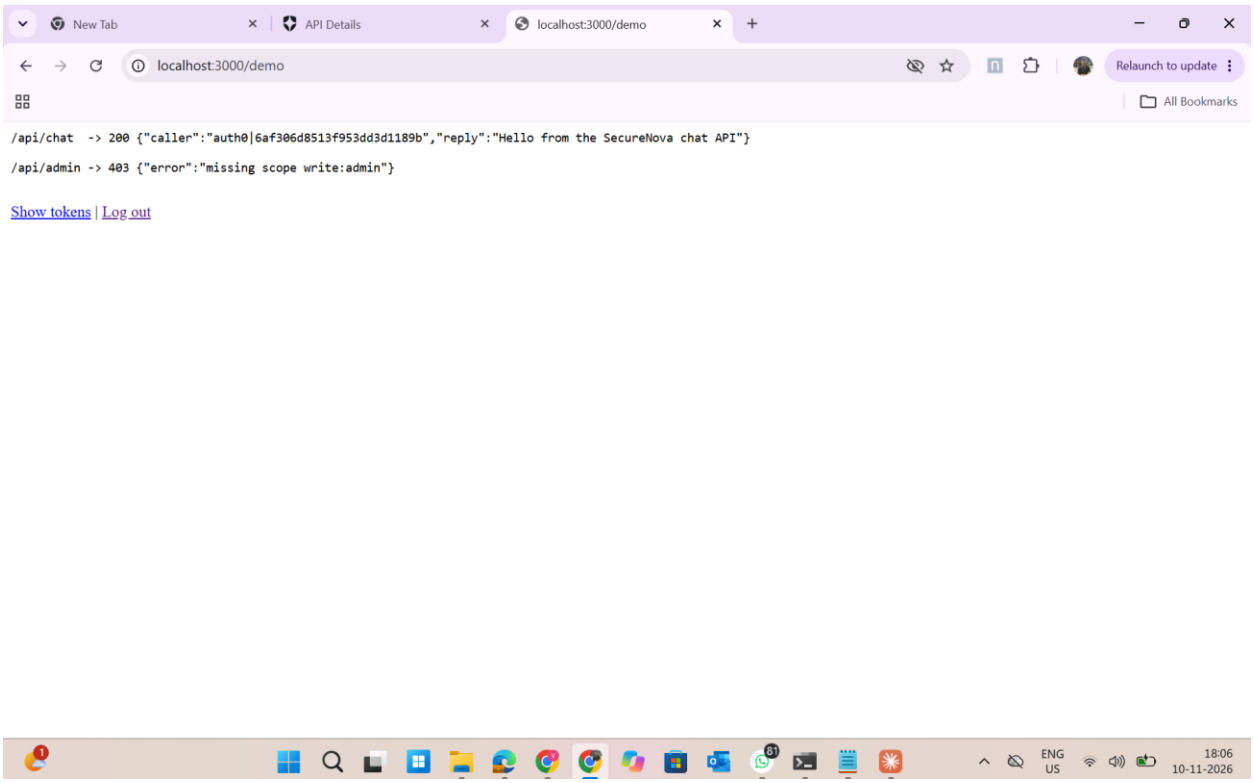
Description: Suspicious IP Throttling and Brute-force Protection are both Enabled. Brute-force Protection uses a custom threshold of 10 maximum attempts with Block Brute-force Logins and Account Lockout switched on. Note: this tenant does not expose a configurable lockout duration; blocked accounts are released through the user unblock email or an admin unblock, which is equal to or stricter than a 15-minute timed lockout.

8 — Terminal — credential rotation script: 200 OK, then 401 Unauthorized on replay



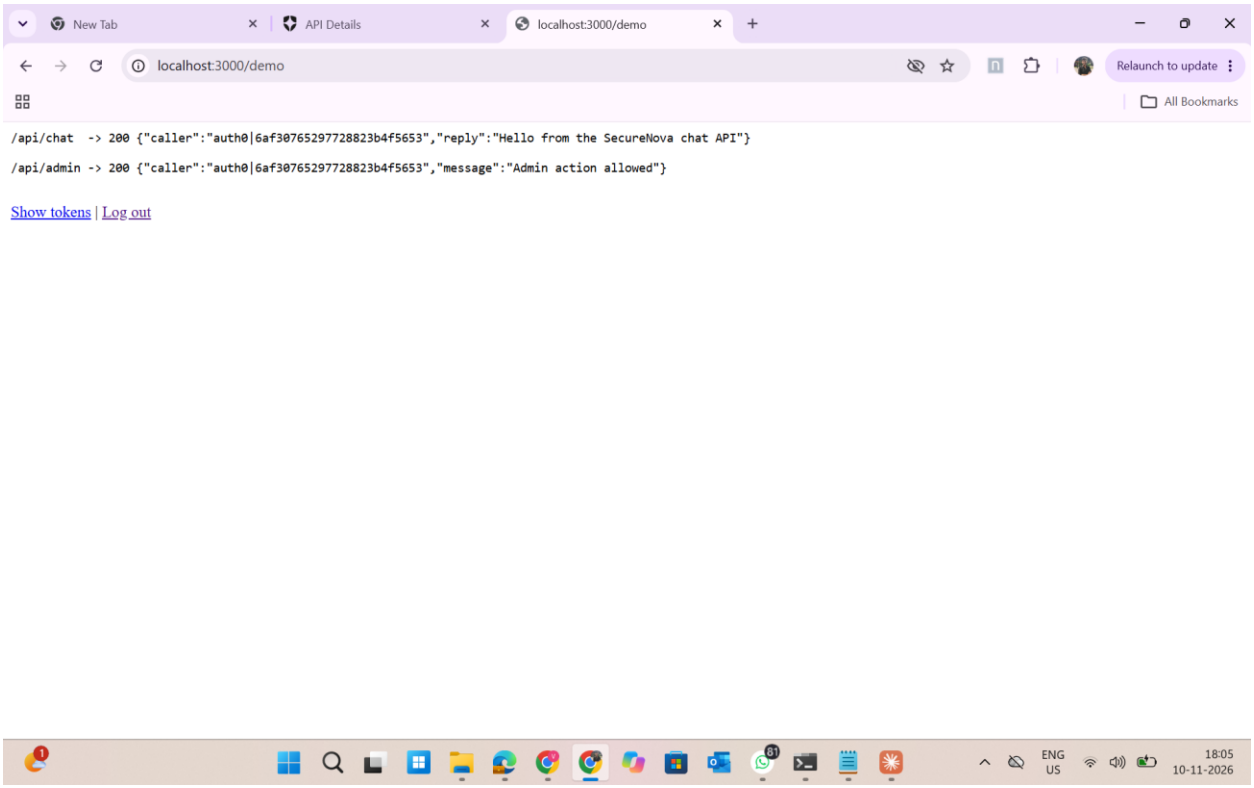
Description: token_rotation.py requests an M2M token via the client_credentials grant with the API access token lifetime set to 60 seconds (expires_in = 60). The first call to /api/chat at 20:08:31 returns 200 OK. After waiting 65 seconds, the same token is replayed at 20:09:36 and is rejected with 401 UNAUTHORIZED. Result: PASS. The token is masked in the output.

Evidence A — Normal user — /api/admin rejected with 403 (missing write:admin)



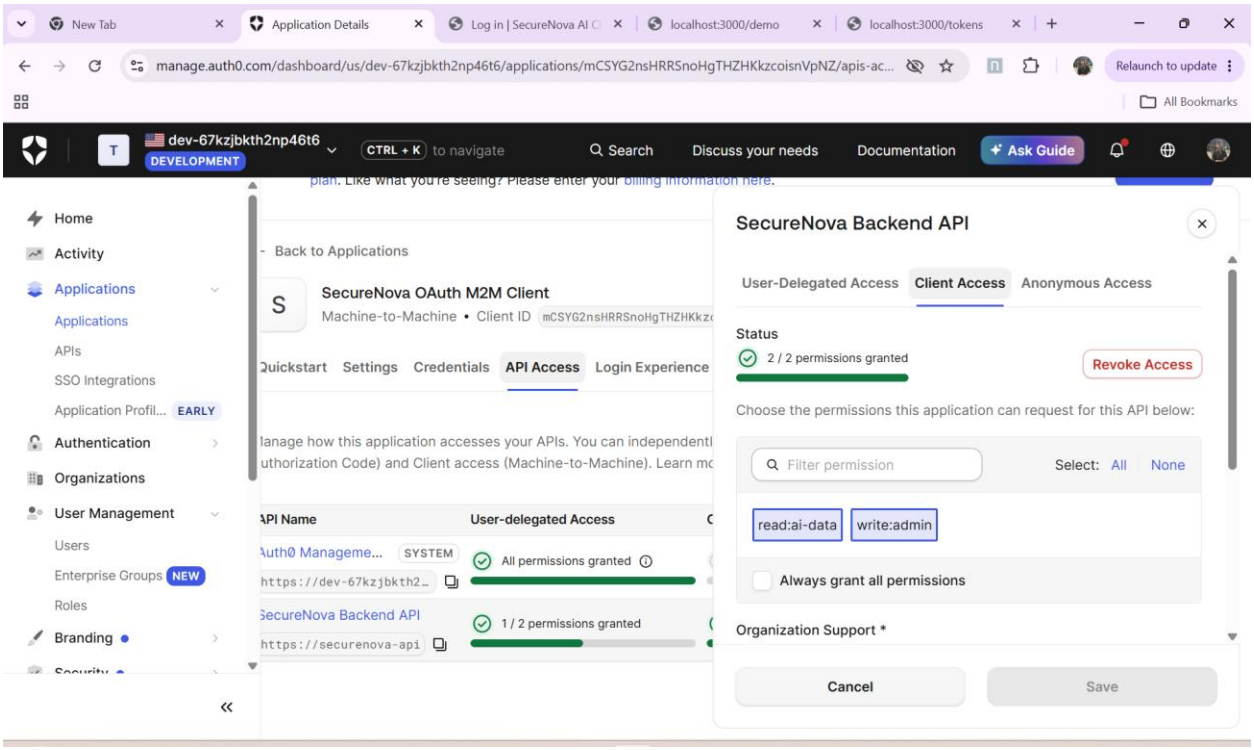
Description: A user holding only read:ai-data receives 200 from /api/chat but 403 {"error":"missing scope write:admin"} from the admin-scoped endpoint, demonstrating least-privilege scope enforcement.

Evidence B — Admin user — /api/admin allowed (200)



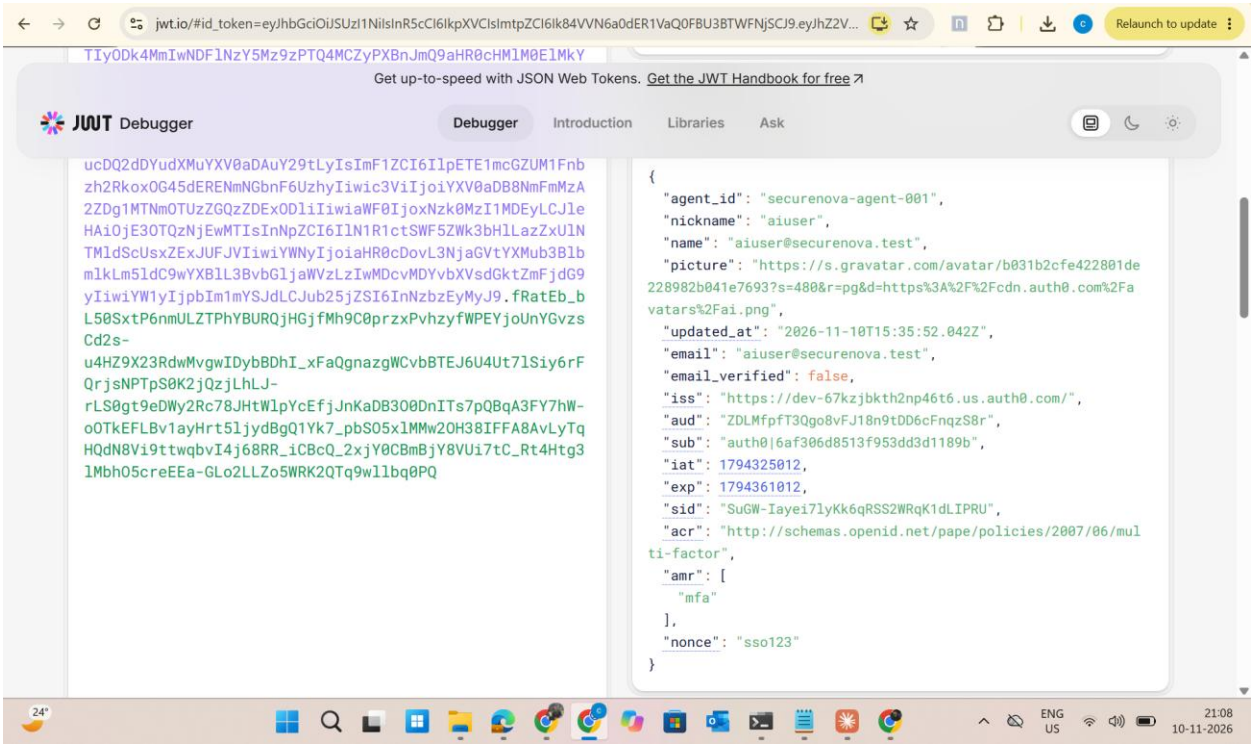
Description: A user granted write:admin receives 200 "Admin action allowed" from the same endpoint, confirming access is decided by the token scope, not by the application.

Evidence C — M2M client — API access permissions granted



Description: The SecureNova OAuth M2M Client is authorised for client access to the SecureNova Backend API with the defined permissions. (Recommendation for Project 4: reduce the agent to read:ai-data only, per least privilege.)

Evidence D — SSO: second registered client accepted without re-authentication



Description: With an active Auth0 session from the SecureNova AI Chat Web App, an /authorize request for a second registered client (Default App, client ID ZDLMfpfT…) completed without prompting for credentials. The resulting ID token for aiuser@securenova.test, decoded at jwt.io, carries aud = the Default App client ID, proving single sign-on across clients through the shared Auth0 session.

Evidence index

#	Evidence	Status
Screenshot 1	Auth0 Applications page — Regular Web App and M2M app registered	Complete
Screenshot 2	Auth0 APIs page — custom scopes read:ai-data and write:admin	Complete
Screenshot 3	jwt.io — decoded access token (RS256, aud, iss, exp, scope, agent_id)	Complete
Screenshot 4	Auth0 Universal Login page with custom branding applied	Complete
Screenshot 5a	Auth0 MFA enrolment — TOTP QR code	Complete
Screenshot 5b	Auth0 MFA challenge — TOTP code required at login	Complete
Screenshot 6	Auth0 Actions editor — post-login Action adding agent_id claim	Complete
Screenshot 7	Auth0 Attack Protection — Brute-force Protection and Suspicious IP Throttling enabled	Complete
Screenshot 8	Terminal — credential rotation script: 200 OK, then 401 Unauthorized on replay	Complete
Evidence A	Normal user — /api/admin rejected with 403 (missing write:admin)	Complete
Evidence B	Admin user — /api/admin allowed (200)	Complete
Evidence C	M2M client — API access permissions granted	Complete
Evidence D	SSO — second client accepted without re-authentication	Complete

Submitted by: Kali Charan Gara — Candidate ID: 14226839